

HW04 — Automation Testing — Báo cáo chính

0. Thông tin sinh viên

Trường	Giá trị
Họ tên	TRƯỜNG THÀNH ĐẠT
MSSV	23127344
Lớp / Nhóm	Kiểm thử phần mềm - 23KTPM3
Assignment	HW04 — Automation Testing (HW04-AI)
Ngày nộp	08/08/2026
Self-Assessed Grade	100 / 100 (chi tiết từng tiêu chí: README.md)
SUT	EShop — https://github.com/ttbhanh/eshop-sut (bản dùng chung, tương ứng eshop-sut)
GitHub repo (public)	https://github.com/trwng-thdat/software-testing (scripts · data · HTML reports)
GitHub Issues	https://github.com/DuyITLOR/group05_eshop/issues — 13 issue #260–#272 (repo của SUT)
Video demo (Task 2)	https://youtu.be/kbkZxUZHS_M
Video demo Agent Skill	https://youtu.be/1FvnyriJITQ

🔴 Hai repo tách biệt — đúng theo bản chất bài làm:

Repo	Vai trò
trwng-thdat/software-testing	Repo bài làm của em — script Selenium, file dữ liệu, 9 báo cáo HTML, ảnh chụp bug, Agent Skill. Toàn bộ commit ở \$5 nằm ở đây.
DuyITLOR/group05_eshop	Repo của SUT (EShop) — nơi tạo 13 bug issue #260–#272 , vì bug thuộc về mã nguồn SUT chứ không thuộc về mã kiểm thử.

Bug được báo trên repo chứa lỗi là cách làm đúng trong thực tế: issue phải nằm ở nơi lập trình viên sửa được, không phải ở repo của người kiểm thử.

Công cụ đã dùng: **Claude Opus 5** (Claude Code, VSCode extension) · **Selenium 4+** (TypeScript + Mocha + Chai) · **mochawesome** (HTML reporter).

1. Phạm vi lựa chọn (Feature Selection)

Theo \$5 đề bài: tự động hóa **đúng 3 feature web** đã chọn ở HW02 — mỗi Pool A/B/C một feature. **Pool D (mobile) không dùng** ở bài này vì HW04 chỉ tự động hóa web frontend.

Feature	Pool	FR ID	Tên feature	Màn hình / route	Số TC tự động hóa
Feature A	A	FR-04	Personal profile management	frontend-web /profile	15 (§1.3.1)
Feature B	B	FR-08	Checkout	frontend-web /checkout	16 (§1.3.2)
Feature C	C	FR-18	Order management (admin)	frontend-admin (tab Đơn hàng , port 5174)	16 (§1.3.3)

Nguồn lựa chọn: kế thừa từ HW02 — không trùng với thành viên khác trong nhóm.

Môi trường thực thi:

Thành phần	Giá trị
OS	Windows 11 Home Single Language
Backend API	http://localhost:3000
Customer web	http://localhost:5173
Admin web	http://localhost:5174
Trình duyệt	Chrome 151.0.7922.76 · Edge 151.0.4129.59 · Firefox 153.0.3

Thành phần	Giá trị
Node.js	v22.22.1
Selenium	selenium-webdriver 4.46.0 · Mocha 10.8.2
Tài khoản test	user <code>hw04.fixture@eshop.test</code> · admin <code>admin@eshop.com</code>

TASK 1 — AI-generated automation scripts

Trọng số: 25 + 25 + 25 = **75/100** (mỗi feature 25 điểm).

1.1 Nguồn tham chiếu đã đọc

Nguồn	Nội dung liên quan
<code>eshop-sut/README.md</code> (SRS) §2 FR-04, dòng 62–68	SDT hợp lệ: bắt đầu bằng <code>0</code> , dài 10–11 chữ số; email không đổi được; không tự đổi <code>role</code>
<code>eshop-sut/README.md</code> (SRS) §4 FR-08, dòng 102–108	Chỉ user đã đăng nhập; tổng tiền không cho sửa trực tiếp ; backend tự tính lại; xóa giỏ sau thanh toán
<code>eshop-sut/README.md</code> (SRS) §4 FR-09, dòng 110–139	5 điều kiện coupon C1–C5, công thức percent/fixed, bảng 4 mã mẫu
<code>eshop-sut/README.md</code> (SRS) §5 FR-10, dòng 141–162	State machine 5 trạng thái; <code>delivered/canceled</code> là trạng thái kết thúc
<code>eshop-sut/README.md</code> (SRS) §6 FR-12, dòng 174–180	Mọi API <code>/api/admin/*</code> yêu cầu JWT hợp lệ + <code>role = 'admin'</code>
<code>eshop-sut/README.md</code> (SRS) §6 FR-18, dòng 218–222	Admin xem mọi đơn; chuyển trạng thái theo FR-10; địa chỉ hiển thị an toàn
<code>eshop-sut/backend/server.js</code> dòng 112–135, 297–330, 525–555	Hành vi backend thật của <code>PUT /api/users/me</code> , <code>POST /api/checkout</code> , <code>PUT /api/admin/orders/:id/status</code> — dùng làm đối chiếu, không dùng làm oracle
<code>eshop-sut/setup_guide.md</code>	Cổng dịch vụ, tài khoản admin mặc định
<code>frontend-web/src/pages/Profile.jsx</code>	DOM thật của màn hình hồ sơ
<code>frontend-web/src/pages/Checkout.jsx</code>	DOM thật của màn hình thanh toán
<code>frontend-admin/src/App.jsx</code>	DOM thật của admin (SPA dạng tab, không có router)
Test case HW02	[Bảng TC gốc — mỗi TC ID thành 1 <code>it()</code>]

1.2 Cấu trúc dự án automation

```
selenium/
.env.example           # STUDENT_ID, WEB_URL, ADMIN_URL, BROWSERS, ...
.mocharc.json
package.json
data/
  fr04-profile.data.json    # 15 test case  ✓
  fr08-checkout.data.json   # 16 test case  ✓
  fr18-admin-orders.data.json # 16 test case  ✓
tests/
  fr04-profile.spec.ts      #  ✓
  fr08-checkout.spec.ts     #  ✓
  fr18-admin-orders.spec.ts #  ✓
utils/
  config.ts  driver.ts  dataLoader.ts  alerts.ts  reportMetadata.ts  bugReporter.ts  api.ts
  profilePage.ts           # page object FR-04
  checkoutPage.ts          # page object FR-08 (/product/:id, /cart, /checkout)
  adminOrdersPage.ts       # page object FR-18 (SPA dạng tab, port 5174)
  runMatrix.ts  verifyReports.ts
reports/
  fr04-profile/{chrome,edge,firefox}.html
  fr08-checkout/{chrome,edge,firefox}.html
```

```
fr18-admin-orders/{chrome,edge,firefox}.html
bug-snapshots/
BUGS.md <TC-ID>.png
```

Cách chạy lại (reproducible):

```
cd selenium
npm install
cp .env.example .env          # điền STUDENT_ID, STUDENT_NAME, URL, tài khoản
npm run typecheck
npm run test:all-browsers      # 3 feature x 3 browser = 9 lượt, tự đóng dấu bảo cáo
# hoặc chạy riêng từng feature:
npm run test:fr04              # FR-04 x 3 browser
npm run test:fr08              # FR-08 x 3 browser
npm run test:fr18              # FR-18 x 3 browser
npm run verify:reports         # cổng kiểm: đếm case, kiểm 9 file HTML + banner Run by:
```

⚠️ **Tài khoản admin:** mật khẩu seed thật là **Admin123!** (backend/database.js:92), **không** phải **admin123**. Nhập sai bị cộng login_attempts +2 mỗi lần và **khóa tài khoản ở lần thứ 3** (server.js:55-60).

⚠️ **Điều kiện chạy FR-08:** SUT phải ở trạng thái seed sạch hoặc ít nhất còn lượt dùng coupon. Bộ test tự phục hồi hạn mức coupon (ensureCouponAllowance), nhưng dữ liệu **orders** sẽ tăng dần qua mỗi lần chạy — điều này **không** ảnh hưởng assertion vì mọi case đều so sánh theo **id** đơn hàng tương đối, không theo số tuyệt đối.

1.3 Data-driven — dữ liệu tách rời khỏi script

Yêu cầu §6: dữ liệu test **phải** nằm ở file **.csv/.json** riêng. Mảng/đối tượng hardcoded trong script **không được chấp nhận**.

Feature	File dữ liệu	Định dạng	Số case	Positive	Negative	Edge
FR-04	data/fr04-profile.data.json	JSON	15	5	7	3
FR-08	data/fr08-checkout.data.json	JSON	16	6	6	4
FR-18	data/fr18-admin-orders.data.json	JSON	16	6	7	3
Tổng			47	17	20	10

Chi tiết từng test case: §1.3.1 (FR-04), §1.3.2 (FR-08), §1.3.3 (FR-18).

Ví dụ một case trong file dữ liệu:

```
{
  "tcId": "TC-PROFILE-01",
  "title": "[Tiêu đề TC]",
  "type": "positive",
  "input": { "...": "..." },
  "expected": { "...": "..." }
}
```

Spec **duyệt** mảng này (for (const c of cases) it(...)), không viết cứng từng **it()** với dữ liệu literal.

1.3.1 Bộ test case — Feature A · Pool A · FR-04 Quản lý hồ sơ cá nhân

Đặc tả tham chiếu: SRS §2 FR-04 (dòng 62–68). Màn hình frontend-web/src/pages/Profile.jsx, API PUT /api/users/me. Quy tắc oracle: **SĐT hợp lệ = bắt đầu bằng 0, dài 10–11 chữ số**; email không đổi được; user chỉ sửa hồ sơ của chính mình và **không được tự đổi role**.

TC ID	Loại	Tiêu đề	Input	Expected (theo SRS)	Assertion pattern
TC-PROFILE-01	positive	Cập nhật đủ 3 trường hợp lệ	name Nguyễn Văn A , phone 0912345678 , address 12 Lê Lợi, Q1	Thông báo "Cập nhật thành công!"; dữ liệu được lưu	1 UI · 2 API
TC-PROFILE-02	positive	Chỉ đổi họ tên, giữ nguyên phone/address	name Trần Thị B	Cập nhật thành công; phone và address không đổi	2 API

TC ID	Loại	Tiêu đề	Input	Expected (theo SRS)	Assertion pattern
TC-PROFILE-03	positive	Dữ liệu vẫn còn sau khi tải lại trang	Cập nhật rồi F5	Form hiển thị đúng giá trị vừa lưu	1 UI
TC-PROFILE-04	positive	SĐT biên dưới 10 chữ số	phone 0123456789	Chấp nhận (đúng 10 chữ số, bắt đầu bằng 0)	1 UI · 2 API
TC-PROFILE-05	positive	SĐT biên trên 11 chữ số	phone 01234567890	Chấp nhận (đúng 11 chữ số)	1 UI · 2 API
TC-PROFILE-06	negative	SĐT 9 chữ số (dưới biên)	phone 091234567	Bị từ chối, hiện thông báo lỗi, không lưu	3 Rejection
TC-PROFILE-07	negative	SĐT 12 chữ số (trên biên)	phone 012345678901	Bị từ chối, không lưu	3 Rejection
TC-PROFILE-08	negative	SĐT không bắt đầu bằng 0	phone 912345678	Bị từ chối theo SRS \$FR-04	3 Rejection
TC-PROFILE-09	negative	SĐT chứa chữ cái	phone 09abc45678	Bị từ chối, không lưu	3 Rejection
TC-PROFILE-10	negative	Bỏ trống họ tên	name `` (rỗng)	Không cho submit (trường required)	3 Rejection
TC-PROFILE-11	negative	Email không sửa được qua UI	Thử nhập vào ô Email	Ô Email disabled, giá trị không đổi	1 UI
TC-PROFILE-12	negative	Không được tự nâng quyền role	PUT /api/users/me kèm {"role": "admin"}	API phải bỏ qua/từ chối trường role ; user vẫn là user	2 API · 5 Security
TC-PROFILE-13	edge	Họ tên chứa ký tự Unicode tiếng Việt có dấu	name Đặng Thị Ngọc Hoà	Lưu và hiển thị đúng, không lỗi encoding	1 UI · 2 API
TC-PROFILE-14	edge	Địa chỉ rất dài (500 ký tự)	address 500 ký tự	Lưu đủ, không cắt chuỗi, không vỡ layout	2 API
TC-PROFILE-15	edge	Địa chỉ chứa payload HTML	address <x	Hiển thị dạng text thuần , không render thẻ HTML	5 Security

1.3.2 Bộ test case — Feature B · Pool B · FR-08 Thanh toán (Checkout)

Đặc tả tham chiếu: SRS \$4 FR-08 (dòng 102–108) và FR-09 Coupon (dòng 110–139). Màn hình frontend-web/src/pages/Checkout.jsx, API POST /api/checkout, POST /api/apply-coupon. Coupon mẫu trong hệ thống: SAVE10 (percent 10%, ngưỡng 300.000đ), BIGBUY (fixed 50.000đ, ngưỡng 500.000đ), VIP100 (fixed 100.000đ, ngưỡng 300.000đ, 2 lượt), EXPIRED (hết hạn 2020-01-01).

TC ID	Loại	Tiêu đề	Input	Expected (theo SRS)	Assertion pattern
TC-CHECKOUT-01	positive	Thanh toán thành công giỏ 1 sản phẩm	1 sản phẩm, đã đăng nhập	Hiện "Thanh toán thành công!"; tạo đơn pending	1 UI · 2 API
TC-CHECKOUT-02	positive	Thanh toán giỏ nhiều sản phẩm	3 sản phẩm khác nhau	Đơn tạo đúng, liệt kê đủ sản phẩm	1 UI · 4 Integrity
TC-CHECKOUT-03	positive	Giỏ hàng được xóa sau khi thanh toán	Thanh toán xong, mở lại /cart	Giỏ hàng rỗng (SRS FR-08)	1 UI
TC-CHECKOUT-04	positive	Áp mã SAVE10 cho đơn đủ ngưỡng	total 400.000đ + SAVE10	discount = 40.000đ; final = 360.000đ	4 Integrity
TC-CHECKOUT-05	positive	Áp mã BIGBUY (fixed)	total 600.000đ + BIGBUY	discount = 50.000đ; final = 550.000đ	4 Integrity
TC-CHECKOUT-06	positive	Mã nhập chữ thường vẫn nhận	save10	Chuẩn hóa thành SAVE10, áp dụng được	1 UI
TC-CHECKOUT-07	negative	Tổng tiền không được sửa trực tiếp	Sửa ô tổng tiền còn 1	UI không cho sửa ; backend tự tính lại (SRS FR-08)	3 Rejection · 5 Security

TC ID	Loại	Tiêu đề	Input	Expected (theo SRS)	Assertion pattern
TC-CHECKOUT-08	negative	Mã không tồn tại	NOTEXIST	Báo lỗi, không giảm giá	3 Rejection
TC-CHECKOUT-09	negative	Mã hết hạn (C2)	EXPIRED	Từ chối vì quá <code>expired_at</code>	3 Rejection
TC-CHECKOUT-10	negative	Chưa đủ ngưỡng đơn hàng (C3)	total 299.000đ + <code>SAVE10</code>	Từ chối vì <code>total < min_order_amount</code>	3 Rejection
TC-CHECKOUT-11	negative	Chưa đăng nhập không thanh toán được (C4)	Guest bấm thanh toán	Bị chặn / yêu cầu đăng nhập	3 Rejection · 5 Security
TC-CHECKOUT-12	negative	Dùng quá số lượt cho phép (C5)	<code>SAVE10</code> lần thứ 2 cùng 1 user	Từ chối vì <code>max_uses_per_user = 1</code>	3 Rejection
TC-CHECKOUT-13	edge	Ngưỡng biên đúng bằng <code>min_order_amount</code>	total 300.000đ + <code>SAVE10</code>	Chấp nhận (điều kiện C3 là <code>>=</code>)	4 Integrity
TC-CHECKOUT-14	edge	Ngưỡng biên thiếu 1đ	total 299.999đ + <code>SAVE10</code>	Từ chối	3 Rejection
TC-CHECKOUT-15	edge	Giảm giá không vượt quá tổng đơn	total 100.000đ + <code>VIP100</code> (100.000đ)	<code>final_amount >= 0</code> , không âm	4 Integrity
TC-CHECKOUT-16	edge	Thanh toán khi giỏ rỗng	Giỏ rỗng	Không tạo được đơn, có thông báo	3 Rejection

1.3.3 Bộ test case — Feature C · Pool C · FR-18 Quản lý đơn hàng (Admin)

Đặc tả tham chiếu: SRS §6 FR-18 (dòng 218–222), state machine FR-10 (dòng 141–162), access control FR-12 (dòng 174–180). Màn hình `frontend-admin/src/App.jsx` tab **Đơn hàng** (port 5174), API `PUT /api/admin/orders/:id/status`. State machine hợp lệ: `pending → confirmed|canceled; confirmed → shipping|canceled; shipping → delivered`. **delivered và canceled là trạng thái kết thúc — không được chuyển tiếp.**

TC ID	Loại	Tiêu đề	Input	Expected (theo SRS)	Assertion pattern
TC-ADMIN-01	positive	Admin xem được đơn của mọi user	Đăng nhập admin, mở tab Đơn hàng	Bảng liệt kê đơn của nhiều user khác nhau	1 UI
TC-ADMIN-02	positive	Chuyển <code>pending → confirmed</code>	Bấm "Xác nhận"	Trạng thái thành "Đã xác nhận"	1 UI · 2 API
TC-ADMIN-03	positive	Chuyển <code>confirmed → shipping</code>	Bấm "Giao hàng"	Trạng thái thành "Đang giao"	1 UI · 2 API
TC-ADMIN-04	positive	Chuyển <code>shipping → delivered</code>	Bấm "Hoàn thành"	Trạng thái thành "Đã giao"	1 UI · 2 API
TC-ADMIN-05	positive	Hủy đơn từ <code>pending</code>	Bấm "Hủy"	Trạng thái thành "Đã hủy"	1 UI · 2 API
TC-ADMIN-06	positive	Hủy đơn từ <code>confirmed</code>	Bấm "Hủy"	Trạng thái thành "Đã hủy"	1 UI · 2 API
TC-ADMIN-07	negative	canceled là trạng thái kết thúc	PUT đơn <code>canceled → delivered</code>	Phải bị từ chối (FR-10)	3 Rejection · 4 Integrity
TC-ADMIN-08	negative	delivered là trạng thái kết thúc	PUT đơn <code>delivered → shipping</code>	Phải bị từ chối	3 Rejection · 4 Integrity
TC-ADMIN-09	negative	Không được nhảy cóc <code>pending → shipping</code>	PUT bỏ qua <code>confirmed</code>	Phải bị từ chối	3 Rejection
TC-ADMIN-10	negative	Không được lùi <code>shipping → pending</code>	PUT lùi trạng thái	Phải bị từ chối	3 Rejection
TC-ADMIN-11	negative	Trạng thái không tồn tại	PUT với <code>status: "abc"</code>	Trả lỗi, không đổi dữ liệu	3 Rejection

TC ID	Loại	Tiêu đề	Input	Expected (theo SRS)	Assertion pattern
TC-ADMIN-12	negative	Token non-admin bị chặn	Gọi <code>/api/admin/orders</code> bằng token user thường	HTTP 401/403 (FR-12)	5 Security
TC-ADMIN-13	negative	Không có token bị chặn	Gọi API không kèm token	HTTP 401	5 Security
TC-ADMIN-14	edge	Địa chỉ giao hàng hiển thị an toàn	Đơn có địa chỉ <code>xss</code>	Hiển thị text thuần , không render HTML (FR-18)	5 Security
TC-ADMIN-15	edge	Đơn không tồn tại	<code>PUT /api/admin/orders/999999/status</code>	HTTP 404	3 Rejection
TC-ADMIN-16	edge	Nút hành động khớp trạng thái hiện tại	Đơn <code>delivered</code>	Không hiện nút chuyển trạng thái nào	1 UI

1.3.4 Tổng hợp phân bố test case

Feature	Tổng	Positive	Negative	Edge	Đạt yêu cầu ≥ 12
FR-04 Personal profile	15	5	7	3	✓
FR-08 Checkout	16	6	6	4	✓
FR-18 Admin orders	16	6	7	3	✓
Tổng	47	17	20	10	✓ (≥ 36)

1.4 Assertion patterns

Yêu cầu §6: mỗi feature dùng **≥ 3 assertion pattern khác biệt**. "Khác biệt" nghĩa là khác loại bằng chứng, không phải 3 lần `assert.equal`.

#	Pattern	Mô tả	Dùng ở FR-04	FR-08	FR-18	Ví dụ TC
1	UI state / text	Kiểm thông báo, giá trị field, sự hiện diện của phần tử	✓	✓	✓	TC-PROFILE-03 · TC-CHECKOUT-03 · TC-ADMIN-16
2	Persistence / API cross-check	Sau thao tác UI, gọi API xác nhận dữ liệu thật sự đã đổi	✓	✓	✓	TC-PROFILE-02 · TC-CHECKOUT-01 · TC-ADMIN-02
3	Negative / rejection	Input sai phải bị từ chối: có lỗi, không điều hướng, không tạo bản ghi	✓	✓	✓	TC-PROFILE-06 · TC-CHECKOUT-10 · TC-ADMIN-09
4	Structural / data integrity	Tổng tiền = Σ line items – giảm giá; trạng thái đơn đúng state machine	—	✓	✓	TC-CHECKOUT-04 · TC-ADMIN-07
5	Security behaviour	Token non-admin bị chặn 401/403; payload XSS render dạng text	✓	✓	✓	TC-PROFILE-12 · TC-CHECKOUT-11 · TC-ADMIN-12/14

Mỗi feature dùng ít nhất 4 pattern khác nhau (FR-04: 1-2-3-5 — FR-08: 1-2-3-4-5 — FR-18: 1-2-3-4-5), vượt yêu cầu tối thiểu 3.

1.5 Kết quả thực thi đa trình duyệt

Yêu cầu §6: mỗi feature chạy trên **cả 3 trình duyệt** → **≥ 9 lượt chạy**. Mỗi lượt sinh 1 báo cáo HTML hiển thị rõ `Run by: {MSSV} + ISO timestamp`.

Bảng tổng hợp 9 lượt chạy

#	Feature	Browser	Tổng TC	Pass	Fail	Skip	Thời lượng	ISO timestamp	Báo cáo HTML
1	FR-04	Chrome	15	11	4	0	12s	2026-08-07T15:39:48.716Z	<code>reports/fr04-profile/chrome.html</code>
2	FR-04	Edge	15	11	4	0	12s	2026-08-07T15:39:48.716Z	<code>.../edge.html</code>

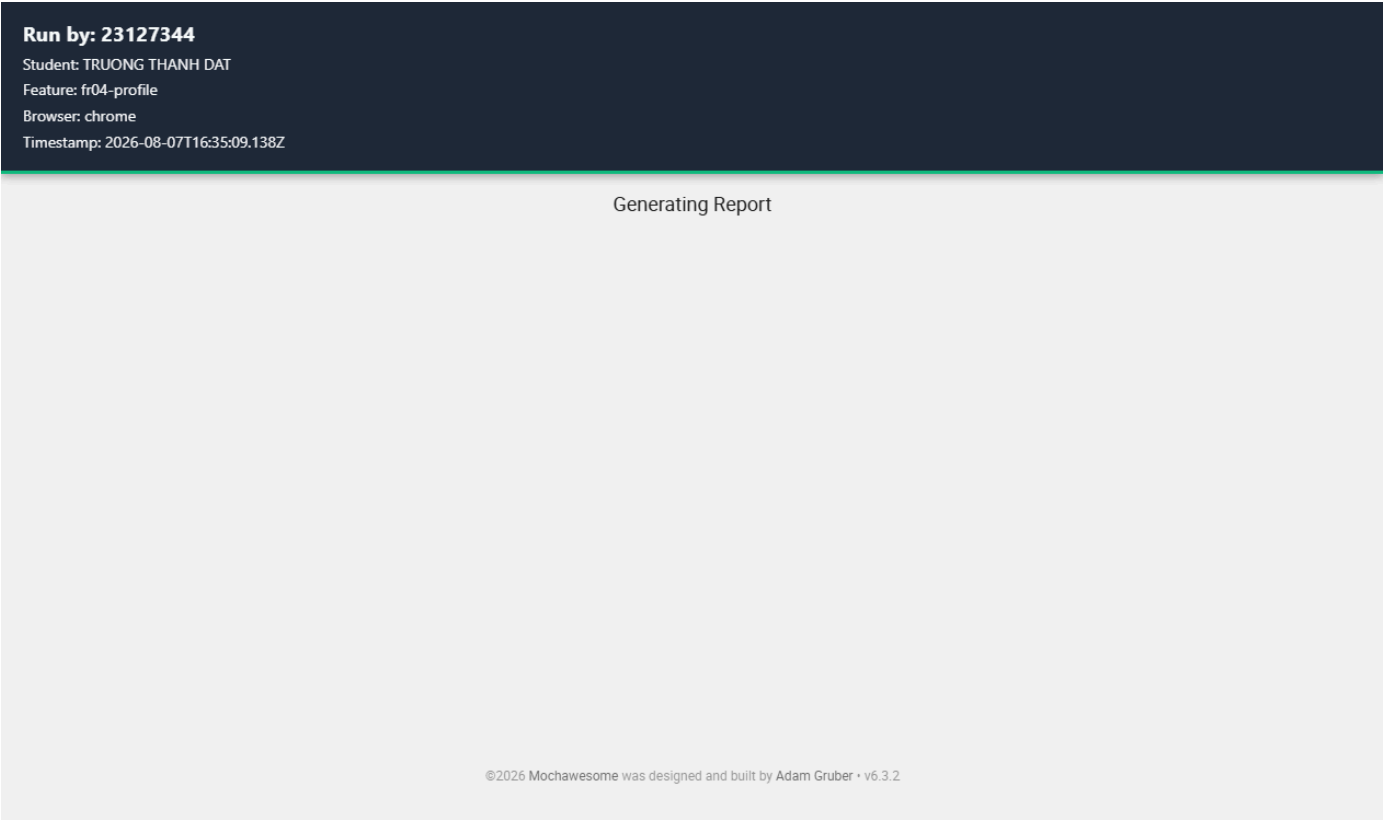
#	Feature	Browser	Tổng TC	Pass	Fail	Skip	Thời lượng	ISO timestamp	Báo cáo HTML
3	FR-04	Firefox	15	11	4	0	15s	2026-08-07T15:39:48.716Z	.../firefox.html
4	FR-08	Chrome	16	11	5	0	60s	2026-08-07T15:41:29.523Z	reports/fr08-checkout/chrome.html
5	FR-08	Edge	16	11	5	0	60s	2026-08-07T15:41:29.523Z	.../edge.html
6	FR-08	Firefox	16	11	5	0	60s	2026-08-07T15:41:29.523Z	.../firefox.html
7	FR-18	Chrome	16	12	4	0	6s	2026-08-07T15:45:07.016Z	reports/fr18-admin-orders/chrome.html
8	FR-18	Edge	16	12	4	0	6s	2026-08-07T15:45:07.016Z	.../edge.html
9	FR-18	Firefox	16	12	4	0	31s	2026-08-07T15:45:07.016Z	.../firefox.html
Tổng			141	102	39	0	9 / 9 báo cáo		

✔️ **Đủ 9 báo cáo HTML tồn tại đồng thời**, đã qua cổng kiểm `npm run verify:reports` (đếm case ≥ 12 /feature, kiểm banner `Run by:` + ISO timestamp + đúng tên browser trong từng file).

Bảng chứng metadata: mỗi file HTML chứa banner hiển thị trực tiếp khi mở bằng trình duyệt:

```
Run by: 23127344
Student: TRUONG THANH DAT
Feature: [feature]
Browser: [chrome|edge|firefox]
Timestamp: [ISO 8601]
```

Ảnh chụp banner (mở file HTML bằng trình duyệt thật):



Ảnh của 2 feature còn lại: `FR-08` · `FR-18`

Khác biệt giữa các trình duyệt

TC ID	Chrome	Edge	Firefox	Nhận xét
TC-PROFILE-04	F	F	F	Defect SUT — tái hiện giống hệt trên cả 3 engine
TC-PROFILE-05	F	F	F	Defect SUT — tái hiện giống hệt trên cả 3 engine
TC-PROFILE-08	F	F	F	Defect SUT — tái hiện giống hệt trên cả 3 engine
TC-PROFILE-12	F	F	F	Defect SUT (leo thang đặc quyền, tầng API nên độc lập browser)
TC-CHECKOUT-03	F	F	F	Defect SUT — <code>clearCart</code> không được gọi
TC-CHECKOUT-04	F	F	F	Defect SUT — công thức percent sai, tầng API nên độc lập browser
TC-CHECKOUT-07	F	F	F	Defect SUT — tổng tiền sửa được trên cả 3 engine
TC-CHECKOUT-13	F	F	F	Defect SUT — so sánh <code>></code> thay vì <code>>=</code> , tầng API
TC-CHECKOUT-16	F	F	F	Defect SUT — đơn rỗng vẫn được tạo
TC-ADMIN-07	F	F	F	Defect SUT — <code>canceled</code> → <code>delivered</code> được chấp nhận, tầng API
TC-ADMIN-12	F	F	F	Defect SUT — thiếu kiểm <code>role</code> , tầng API nên độc lập browser
TC-ADMIN-14	F	F	F	Defect SUT — XSS qua <code>dangerouslySetInnerHTML</code> trên cả 3 engine
TC-ADMIN-16	F	F	F	Defect SUT — UI hiện nút chuyển tiếp ở trạng thái kết thúc

Kết luận: không có khác biệt giữa các trình duyệt — FR-04 cho 11 PASS / 4 FAIL, FR-08 cho 11 PASS / 5 FAIL, FR-18 cho 12 PASS / 4 FAIL, và cả 3 lượt của mỗi feature đều fail đúng cùng một tập TC. Điều này củng cố kết luận rằng 13 TC FAIL là defect thật của SUT chứ không phải lỗi timing hay lỗi riêng của một engine.

Riêng FR-18 chạy nhanh hơn hẳn (6s trên Chrome/Edge) vì phần lớn tiền điều kiện được dựng qua API thay vì click qua UI; Firefox chậm hơn (31s) do chi phí khởi tạo `geckodriver`, **không** phải do khác biệt hành vi — kết quả pass/fail giống hệt.

1.6 Human review — AI sai/thiếu ở đâu và vì sao

#	AI sinh ra gì	Sai/thiếu ở chỗ nào	Cách em sửa	Nguyên nhân gốc
1	Giả định ô Địa chỉ là <code><input></code>	Source thật dùng <code><textarea></code> (<code>Profile.jsx:150</code>) → selector <code>input[placeholder=...]</code> không bao giờ khớp	Đọc JSX trước khi viết selector; dùng <code>textarea[placeholder="Nhập địa chỉ của bạn"]</code>	Giới hạn mô hình — suy từ template e-commerce chung thay vì đọc DOM thật
2	Ô Họ Tên không có <code>name/id/placeholder</code> để bám	Không có selector tier 1–2 khả dụng; ô Email cũng là <code>input[type=text]</code> nên dễ bắt nhầm	Dùng XPath theo <code><label>Họ Tên</label></code> + ghi chú rõ ràng ràng buộc i18n trong <code>profilePage.ts</code>	Đặc thù feature — SUT không có <code>data-testid</code> nào
3	<code>--reporter-options</code> (số nhiều) trong lệnh mocha	Mocha 10 dùng <code>--reporter-option</code> (số ít); dạng số nhiều bị bỏ qua im lặng → không sinh file HTML nào	Đổi sang số ít ở cả <code>package.json</code> và <code>runMatrix.ts</code>	Giới hạn mô hình — nhầm cú pháp giữa các major version
4	<code>spawnSync('npx.cmd', ...)</code> trong runner đa trình duyệt	Node chặn spawn file <code>.cmd</code> khi không bật shell → <code>EINVAL</code> , mocha không hề chạy	Gọi thẳng <code>process.execPath + require.resolve('mocha/bin/mocha.js')</code> , tránh luôn vấn đề path có dấu cách	Giới hạn mô hình — không tính tới đặc thù Windows
5	Chốt idempotent của banner dùng <code>html.includes("Run by: ")</code>	mochawesome nhúng cả kết quả vào <code>data-raw</code> trên <code><body></code> , mà tên suite đã chứa "Run by:" → hàm tương đã chèn rồi và bỏ qua , báo cáo không hề được đóng dấu	Đổi sang marker riêng <code>data-hw04-metadata-banner</code> ; đồng thời siết <code>verifyReports.ts</code> để chỉ chấp nhận banner thật	Giới hạn mô hình — không lường được chuỗi trùng trong dữ liệu serialize
6	Chèn banner bằng regex <code><body([>]*)></code>	Thuộc tính <code>data-raw</code> chứa ký tự <code>></code> → regex khớp sai dấu đóng,	Neo vào <code></head></code> bằng cắt chuỗi thay vì parse thẻ <code><body></code>	Giới hạn mô hình — giả định HTML

#	AI sinh ra gì	Sai/thiếu ở chỗ nào	Cách em sửa	Nguyên nhân gốc
		làm hỏng markup		"sạch"
7	Baseline <code>phone = "0900000000"</code> (đúng SRS) dùng cho mọi case	Chính regex lỗi của SUT chặn baseline này, khiến 6 case <i>không</i> kiểm SĐT (tên, địa chỉ, Unicode, XSS) cũng fail lây → che mất thứ chúng cần kiểm	Đổi baseline sang <code>912345678</code> (build hiện tại chấp nhận) + ghi chú lý do; luật SĐT theo SRS vẫn assert đủ ở TC-04...09	Đặc thù feature — defect ở một trường lan sang các case dùng chung form
8	TC-PROFILE-12 assert <code>role === "user"</code> ở tiền điều kiện và không dọn dẹp	Lần chạy trước đã leo thang thật, tài khoản còn <code>admin</code> vĩnh viễn → test fail ở dòng tiền điều kiện chứ không phải ở phát hiện, và đầu đọc mọi lượt chạy sau	Reset <code>role</code> về <code>user</code> trong <code>beforeEach</code> ; bọc assert trong <code>try/finally</code> để luôn hoàn nguyên kể cả khi fail	Chất lượng prompt — chưa yêu cầu test phải tự cô lập trạng thái
9	Đăng nhập bằng cách điền form UI ở mỗi test	<code>/api/login</code> cộng <code>login_attempts</code> +2 mỗi lần sai và khóa ở 3 (<code>server.js:55-60</code>) → nguy cơ khóa tài khoản giữa chừng	Seed phiên qua API rồi bơm JWT vào <code>localStorage.token</code> đúng như <code>AuthContext</code> đọc	Đặc thù feature — cơ chế khóa tài khoản của SUT
10	Ảnh chụp bug của lượt chạy cũ không bị xóa	Còn PNG của TC nay đã PASS → bằng chứng sai lệch	<code>resetBugLog()</code> xóa sạch <code>*.png</code> trước mỗi lượt matrix	Chất lượng prompt — chưa nêu yêu cầu "bằng chứng phải khớp lần chạy hiện tại"
11	(FR-08) Giả định giỏ hàng seed được qua API hoặc <code>localStorage</code>	<code>CartContext.jsx</code> giữ giỏ trong <code>useState([])</code> thuần — không persist, không gọi server. <code>POST /api/cart</code> có thật nhưng ghi vào map in-memory mà <code>Checkout.jsx</code> không đọc → giỏ chỉ tồn tại trong một phiên SPA sống , mọi <code>driver.get()</code> đều xóa sạch	Seed giỏ bằng click thật trên <code>/product/:id</code> , và điều hướng client-side bằng <code>history.pushState</code> + <code>popstate</code> để không remount <code>CartProvider</code>	Giới hạn mô hình — suy từ mẫu e-commerce có giỏ hàng persistent
12	(FR-08) Chỉ click 1 lần vào nút "Thêm vào giỏ hàng"	<code>ProductDetail.jsx:24-32</code> có defect cài sẵn: <code>clickCount</code> nuốt trọn click đầu tiên , chỉ click thứ 2 mới gọi <code>addToCart</code> → giỏ luôn rỗng, 16/16 case không tới được checkout	Click lặp tới khi nút đổi nhãn thành "Đã thêm" (tối đa 3 lần), kèm chú thích rõ đây là workaround cho bug ngoài phạm vi FR-08	Đặc thù feature — defect của FR-06 chặn đường vào FR-08
13	(FR-08) Đọc số tiền coupon theo thứ tự xuất hiện của ký tự <code>đ</code>	Khối coupon render 3 số tiền, số đầu nằm trong câu thông báo ("Giảm 50,000 đ") → parser hiểu nhầm thông báo là <code>discount</code> và <code>discount</code> thật thành <code>final</code> → TC-05/06 FAIL oan dù SUT trả đúng	Đổi sang bấm nhãn Tiết kiệm / Thành tiền thay vì vị trí; xác minh chéo bằng gọi thẳng API (<code>curl</code>) trước khi kết luận defect	Giới hạn mô hình — parse theo vị trí thay vì theo ngữ nghĩa
14	(FR-08) TC-12 (giới hạn lượt dùng) tiêu luôn lượt của mã seed <code>BIGBUY</code>	<code>coupon_usage</code> chỉ ghi thêm và không có API xóa → sau lần chạy đầu, <code>BIGBUY</code> cạn vĩnh viễn với tài khoản fixture, khiến TC-05/06 FAIL ở mọi lần chạy sau — nhìn hệt như defect	TC-12 tự tạo mã dùng-một-lần <code>HW04LIMIT</code> rồi xóa trong <code>finally</code> ; thêm <code>ensureCouponAllowance()</code> re-mint mã seed khi phát hiện đã cạn	Chất lượng prompt — chưa yêu cầu test phải idempotent qua nhiều lần chạy
15	(FR-08) Tin rằng cờ <code>--spec</code> sẽ thay thế spec trong <code>.mocharc.json</code>	Mocha gộp hai nguồn → mỗi lượt chạy FR-08 kéo theo cả suite FR-04, báo cáo <code>fr08-checkout/chrome.html</code> chứa 31	Bỏ hẳn khóa <code>spec</code> khỏi <code>.mocharc.json</code> , để mỗi lượt tự khai báo spec; ghi chú lý do ngay trong file config để không ai thêm lại	Giới hạn mô hình — nhầm ngữ nghĩa merge/override của config Mocha

#	AI sinh ra gì	Sai/thiếu ở chỗ nào	Cách em sửa	Nguyên nhân gốc
		test của 2 feature. Vẫn "chạy xanh" nên rất dễ bỏ lọt		
16	(FR-08) <code>resetBugLog()</code> xóa toàn bộ *.png trước mỗi lượt matrix	Đúng khi chỉ có 1 feature, nhưng khi có 2 thì feature chạy sau xóa sạch bằng chứng của feature chạy trước — chạy FR-08 làm mất cả 4 ảnh <code>TC-PROFILE-*.png</code> mà \$1.8 đang trỏ link tới, và <code>BUGS.md</code> chỉ còn bug của 1 feature	Đổi <code>resetBugLog(feature, prefixes)</code> chỉ xóa ảnh thuộc tiền tố TC của chính feature đó; <code>BUGS.md</code> được ghép lại từ các file mảnh theo từng feature trong <code>.sections/</code>	Đặc thù feature — giải pháp đúng cho 1 feature nhưng sai khi mở rộng ra nhiều feature
17	(FR-18) Mật khẩu admin <code>admin123</code> — chép từ chính <code>SKILL.md</code> và <code>.env.example</code>	Mật khẩu seed thật là <code>Admin123!</code> (<code>database.js:92</code>). Toàn bộ suite FR-18 chết ngay ở before hook với HTTP 401. Nguy hiểm hơn: <code>/api/login</code> cộng <code>login_attempts +2</code> mỗi lần sai và khóa ở 3 (<code>server.js:55-60</code>) — retry vài lần là tự khóa tài khoản admin của chính mình	Đọc <code>database.js</code> lấy giá trị thật, sửa <code>.env + .env.example</code> ; sửa luôn gốc ở <code>SKILL.md:49,102</code> và <code>references/eshop-notes.md:15</code> kèm cảnh báo về cơ chế khóa, để lần sau skill không truyền tiếp giá trị sai	Giới hạn mô hình — đoán mật khẩu theo dạng thường gặp thay vì đọc file seed; sai lan sang cả skill và tồn tại qua 2 feature trước mà không lộ vì FR-04/FR-08 không dùng tài khoản admin
18	(FR-18) Dự đoán defect FR-18 chỉ từ đọc source: 2 lỗi (<code>canceled</code> → <code>delivered</code> , XSS địa chỉ)	Bỏ sót defect ngghiêm trọng nhất của cả bài: <code>authenticateToken</code> (<code>server.js:100-110</code>) chỉ verify chữ ký JWT mà không kiểm role , nên mọi endpoint <code>/api/admin/*</code> mở toang cho user thường. Đọc riêng route handler thì không thấy — phải đọc middleware mới lộ	Chạy thật mới phát hiện (TC-ADMIN-12 trả HTTP 200 thay vì 401/403) → ghi nhận BUG-11 Critical. Bài học: đọc source giúp định hướng ca kiểm thử, nhưng không thay được chạy thật	Giới hạn mô hình — đọc theo từng route mà không truy ngược chuỗi middleware dùng chung
19	(Cả 3 feature) Banner <code>Run by:</code> chèn vào giữa <code></head></code> và <code><body></code>	Đây không phải vị trí hợp lệ cho nội dung hiển thị → trình duyệt đẩy khối này ra khỏi luồng render. Chuỗi <code>Run by: 23127344</code> có trong file nhưng mở báo cáo lên không nhìn thấy gì — đúng thứ \$11 đề bài bắt buộc phải thấy được. Cả 9 báo cáo đều dính, và <code>verifyReports.ts</code> vẫn báo "All checks passed" vì nó chỉ đọc file dạng text . Người dùng phát hiện bằng mắt, không phải do công kiểm	Chèn ngay sau thẻ <code><body></code> mở , trước <code><div id="report"></code> (nơi <code>mochawesome</code> mount React), thêm <code>position:sticky + z-index</code> để bám đầu trang khi cuộn. Siết <code>verifyReports.ts</code> : so sánh offset của banner với vị trí kết thúc thẻ <code><body></code> , banner nằm ngoài → FAIL. Thêm <code>npm run verify:banner</code> mở báo cáo bằng Chrome thật rồi kiểm <code>isDisplayed()</code> + kích thước hộp + <code>visibility</code> trước khi chụp ảnh làm bằng chứng	Giới hạn mô hình — chọn điểm neo <code></head></code> cho "an toàn" mà không kiểm chứng vị trí hợp lệ của nội dung trong HTML; và oracle sai tầng : kiểm bytes trong khi yêu cầu là kiểm hiển thị

Nhận xét tổng hợp: Nhóm sai nặng nhất không nằm ở logic test mà ở **hạ tầng báo cáo** (#3, #4, #5, #6, #16, #19) — đều là loại lỗi "chạy không báo lỗi nhưng không sinh ra bằng chứng hợp lệ", nguy hiểm vì rất dễ tưởng đã xong. Nhóm thứ hai là **giả định về DOM và trạng thái** (#1, #2, #7, #8, #9): AI suy từ mẫu e-commerce phổ biến thay vì đọc source thật, và mặc định mỗi test chạy trên môi trường sạch. Nhóm thứ ba, chỉ lộ ra khi **tái sử dụng** skill cho feature thứ 2 và thứ 3 (#16, #17): giải pháp đúng cho một feature lại sai khi có nhiều feature, và một giá trị sai nằm sẵn trong tài liệu skill thì **tự nhân bản qua mọi lần dùng lại**.

Đáng chú ý nhất là **#19**: banner `Run by:` nằm sai vị trí trong HTML nên **không hề hiển thị**, trong khi công kiểm tự động vẫn báo "All checks passed" suốt 3 feature — lỗi này cuối cùng do **người dùng phát hiện bằng mắt**, không phải do bộ kiểm chứng. Cùng với #5, đây là lần thứ hai `verifyReports.ts` cho **false negative**, và cả hai lần đều vì oracle kiểm **sai tầng**: đề bài yêu cầu bằng chứng *nhìn thấy được*, mà gate chỉ kiểm *chuỗi ký tự có trong file*. Đó là lý do bổ sung `verify:banner` — mở báo cáo bằng trình duyệt thật rồi mới kết luận.

Bài học khi prompt lần sau: (1) bắt buộc đọc JSX/handler thật trước khi sinh selector; (2) luôn kiểm chứng *bằng chứng đầu ra* chứ không chỉ kiểm test pass/fail — chính `verifyReports.ts` lỏng lẻo đã suýt cho qua 3 báo cáo chưa đóng dấu; (3) yêu cầu rõ mỗi test phải tự khôi phục trạng thái, đặc biệt trên SUT có defect cho phép thay đổi không hoàn nguyên.

1.7 Test case không tự động hóa được

Yêu cầu §6: phải liệt kê và giải thích.

TC ID	Feature	Nội dung	Lý do không tự động hóa được	Cách kiểm thay thế
—	FR-04	—	—	—
—	FR-08	—	—	—
—	FR-18	—	—	—

FR-04: không có TC nào phải bỏ — cả 15/15 test case đều tự động hóa được và đã thực thi trên cả 3 trình duyệt.

Ghi chú về TC-PROFILE-12: case này kiểm ở **tầng API** (`PUT /api/users/me` kèm `role`) thay vì qua UI, vì màn hình `/profile` không hề render ô nhập `role` — bề mặt tấn công duy nhất là request body. Đây vẫn là tự động hóa đầy đủ, chỉ khác điểm tác động.

FR-08: không có TC nào phải bỏ — cả 16/16 test case đều tự động hóa được và đã thực thi trên cả 3 trình duyệt.

Ghi chú về **điểm tác động** của 4 case FR-08 kiểm ở tầng API thay vì UI — đây là lựa chọn thiết kế, không phải giới hạn:

TC	Vì sao kiểm ở tầng API
TC-CHECKOUT-12	Cần tiêu hết hạn mức lượt dùng rồi thử lại. Qua UI sẽ phải thanh toán thật nhiều lần và làm bắn dữ liệu dùng chung; qua API thì tạo/xóa được mã dùng-một-lần riêng.
TC-CHECKOUT-13 / 14	Kiểm biên đúng bằng <code>min_order_amount</code> (300.000đ và 299.999đ). Catalogue rẻ nhất đã 4.000.000đ nên không thể ghép giỏ ra đúng số tiền biên; lượt cần kiểm (toán tử so sánh) nằm trọn trong endpoint.
TC-CHECKOUT-15	Cần đơn sát ngưỡng để lộ khả năng <code>final_amount</code> âm — cùng lý do trên.

TC-CHECKOUT-11 kiểm ở **cả hai** tầng: gọi `POST /api/checkout` không token (phải 401) **và** thao tác UI thật với người dùng đã đăng xuất (phải bị chặn trước khi vào `/checkout`).

FR-18: không có TC nào phải bỏ — cả 16/16 test case đều tự động hóa được và đã thực thi trên cả 3 trình duyệt.

Ghi chú về **điểm tác động** của các case FR-18 kiểm ở tầng API:

TC	Vì sao kiểm ở tầng API
TC-ADMIN-07 ... 11	Kiểm chuyển đổi trạng thái không hợp lệ , mà UI cố tình không render nút cho hầu hết các chuyển đổi này (không có nút <code>pending → shipping</code> , không có nút lùi trạng thái). Nếu chỉ kiểm qua UI thì test sẽ "pass" vì không tìm thấy nút — pass giả , không hề chứng minh được server có chặn hay không. Endpoint mới là nơi đặt luật state machine.
TC-ADMIN-12 / 13	Kiểm access control . Bề mặt tấn công là request gọi thẳng API kèm token sai quyền — kiểm qua UI vô nghĩa vì <code>App.jsx:65-68</code> chỉ chặn phía client.
TC-ADMIN-15	Đơn không tồn tại thì không có dòng nào trên bảng để bấm.

Ngược lại TC-ADMIN-01...06, 14, 16 đều kiểm **thật trên UI** (click tab, click nút hành động, đọc nhãn trạng thái, đọc ô địa chỉ), và TC-ADMIN-02...06 còn đối chiếu chéo xuống API để chắc chắn nhãn hiển thị khớp dữ liệu đã lưu.

1.8 Bug report

Yêu cầu §6: chỗ nào assertion fail mà lộ ra defect thật → ghi bug **cả trong báo cáo Markdown lẫn trên GitHub Issues**, mỗi issue **kèm ảnh chụp**.

Phân loại kết quả FAIL

Loại	FR-04	FR-08	FR-18	Xử lý
Lỗi script (selector/wait/expected sai)	6	3	0	Đã sửa script, chạy lại → PASS
Lỗi cấu hình môi trường	0	0	1	Sai mật khẩu admin → sửa <code>.env</code> + gốc ở skill
Defect thật của SUT	4	5	4	Giữ nguyên test FAIL làm bằng chứng, log bug

Chi tiết 6 FAIL do lỗi script ở FR-04 (lượt chạy đầu tiên → đã sửa): TC-PROFILE-01/02/03/13/14/15 ban đầu fail vì `BASELINE.phone = "0900000000"` (đúng SRS) lại bị chính regex lỗi của SUT chặn, khiến các case *không* kiểm SĐT cũng không submit được. Đã đổi baseline sang `912345678` — giá trị build hiện tại chấp nhận — để mỗi case kiểm đúng thứ nó cần kiểm. Quy tắc SĐT theo SRS vẫn được assert **nguyên vẹn** ở TC-PROFILE-04...09.

Chi tiết 3 FAIL do lỗi script ở FR-08 (đã sửa, xem §1.6 dòng 12–14):

1. **TC-CHECKOUT-01...16 (toàn bộ)** — giỏ hàng luôn rỗng vì nút "Thêm vào giỏ hàng" nướ click đầu tiên (`ProductDetail.jsx:24-32`). Sửa: click lập tới khi nhấn đổi thành "Đã thêm".
2. **TC-CHECKOUT-05/06** — parser đọc số tiền coupon theo vị trí, hiểu nhầm câu thông báo "Giảm 50,000 đ" là `discount`. Sửa: bấm nhấn **Tiết kiệm/Thành tiền**. **Đã xác minh chéo bằng `curl` trực tiếp lên `/api/apply-coupon` trước khi kết luận** — API trả đúng `{"discount_amount":50000,"final_amount":3950000}`, chứng minh đây là lỗi script chứ không phải defect.
3. **TC-CHECKOUT-05/06 (lần 2)** — TC-12 tiêu cạn lượt dùng duy nhất của mã seed `BIGBUY`, khiến 2 case này fail ở mọi lần chạy sau. Sửa: TC-12 dùng mã dùng-một-lần tự tạo rồi xóa; thêm `ensureCouponAllowance()`.

Ba lỗi này đều **không** được sửa bằng cách nới assertion — chúng được sửa ở tầng *dựng dữ liệu và đọc kết quả*, còn oracle theo SRS giữ nguyên.

Danh sách bug

Bug ID	TC ID	Feature	Mức độ	Mô tả ngắn	Expected (trích SRS)	Actual	Browser bị ảnh hưởng	Ảnh chụp	GitHub Issue
BUG-01	TC-PROFILE-04	FR-04	High	SĐT hợp lệ 10 chữ số bắt đầu bằng 0 bị từ chối	SRS §2 FR-04: SĐT bắt đầu bằng 0, dài 10–11 chữ số → hợp lệ	Alert "Số điện thoại không hợp lệ...", không lưu	All (3/3)	TC-PROFILE-04.png	#263
BUG-02	TC-PROFILE-05	FR-04	High	SĐT hợp lệ 11 chữ số bắt đầu bằng 0 bị từ chối	SRS §2 FR-04: 11 chữ số là biên trên hợp lệ	Alert "Số điện thoại không hợp lệ...", không lưu	All (3/3)	TC-PROFILE-05.png	#264
BUG-03	TC-PROFILE-08	FR-04	Medium	SĐT không bắt đầu bằng 0 lại được chấp nhận	SRS §2 FR-04: SĐT hợp lệ phải bắt đầu bằng số 0	"Cập nhật thành công!", giá trị sai đặc tả được lưu	All (3/3)	TC-PROFILE-08.png	#269
BUG-04	TC-PROFILE-12	FR-04	Critical	Leo thang đặc quyền — user tự đặt role: "admin" qua <code>PUT /api/users/me</code> thành công	SRS §2 FR-04: người dùng không thể tự thay đổi thuộc tính role	HTTP 200, role đổi từ <code>user</code> → <code>admin</code> , tồn tại trong DB	All (tầng API)	TC-PROFILE-12.png	#260
BUG-05	TC-CHECKOUT-03	FR-08	Medium	Giỏ hàng không được xóa sau khi thanh toán thành công	SRS §4 FR-08: xóa giỏ hàng sau khi thanh toán	Mở lại <code>/cart</code> vẫn thấy nguyên sản phẩm vừa mua	All (3/3)	TC-CHECKOUT-03.png	#270
BUG-06	TC-CHECKOUT-04	FR-08	High	Công thức giảm giá percent bị đảo → giảm giá âm, khách phải trả nhiều hơn	SRS §4 FR-09: <code>SAVE10</code> giảm 10% → giảm 400.000đ, còn 3.600.000đ	<code>discount_amount = -36.000.000đ</code> , <code>final_amount = 40.000.000đ</code> (gấp 10 lần)	All (tầng API)	TC-CHECKOUT-04.png	#265
BUG-07	TC-CHECKOUT-07	FR-08	Critical	Khách tự sửa được tổng tiền và server lưu thẳng giá trị đó — trả 1đ cho đơn 6 triệu	SRS §4 FR-08: tổng tiền không cho sửa trực tiếp ; backend tự tính lại	Ô tổng tiền là <code><input type="number"></code> sửa được; đơn được tạo với <code>total_amount = 1</code>	All (3/3)	TC-CHECKOUT-07.png	#261

Bug ID	TC ID	Feature	Mức độ	Mô tả ngắn	Expected (trích SRS)	Actual	Browser bị ảnh hưởng	Ảnh chụp	GitHub Issue
BUG-08	TC-CHECKOUT-13	FR-08	Medium	Đơn đúng bằng ngưỡng tối thiểu bị từ chối (lỗi biên > thay vì >=)	SRS §4 FR-09 C3: điều kiện là total_amount >= min_order_amount	HTTP 400 "Đơn hàng chưa đủ giá trị tối thiểu 300,000 đ" với đơn đúng 300.000đ	All (tầng API)	TC-CHECKOUT-13.png	#271
BUG-09	TC-CHECKOUT-16	FR-08	High	Giỏ rỗng vẫn tạo được đơn hàng	SRS §4 FR-08: không được tạo đơn khi giỏ rỗng	Hiện "Thanh toán thành công!" và sinh thêm 1 bản ghi trong orders	All (3/3)	TC-CHECKOUT-16.png	#266
BUG-10	TC-ADMIN-07	FR-18	High	canceled → delivered được chấp nhận — đơn đã hủy biến thành đã giao	SRS §5 FR-10: canceled là trạng thái kết thúc, không chuyển tiếp	HTTP 200 {"message": "Order status updated"}, status đổi thành delivered	All (tầng API)	TC-ADMIN-07.png	#267
BUG-11	TC-ADMIN-12	FR-18	Critical	Thiếu kiểm soát quyền — token user thường đọc được mọi API /api/admin/*	SRS §6 FR-12: mọi API /api/admin/* yêu cầu JWT hợp lệ và role = 'admin'	GET /api/admin/orders bằng token user thường trả HTTP 200 kèm toàn bộ đơn hàng của mọi user	All (tầng API)	TC-ADMIN-12.png	#262
BUG-12	TC-ADMIN-14	FR-18	High	XSS lưu trữ — địa chỉ giao hàng được render thành HTML thật	SRS §6 FR-18: địa chỉ giao hàng phải hiển thị an toàn (text thuần)	Địa chỉ xss bị render thành thẻ , đọc lại chỉ còn xss	All (3/3)	TC-ADMIN-14.png	#268
BUG-13	TC-ADMIN-16	FR-18	Medium	UI mời chuyển tiếp từ trạng thái kết thúc — đơn canceled vẫn hiện nút "Đánh dấu Đã giao"	SRS §5 FR-10: delivered/canceled là trạng thái kết thúc	Đơn canceled hiện nút "Đánh dấu Đã giao"; đơn delivered thì đúng (không có nút)	All (3/3)	TC-ADMIN-16.png	#272

Nguyên nhân gốc (đối chiếu source, đã xác nhận bằng chạy thật):

- BUG-01/02/03 cùng một gốc: `frontend-web/src/pages/Profile.jsx:43` dùng regex `/^[1-9][0-9]{8,9}$/` — yêu cầu chữ số đầu là **1–9** và độ dài **9–10**, trong khi SRS yêu cầu chữ số đầu là **0** và độ dài **10–11**. Hai luật loại trừ nhau ngay ở chữ số đầu tiên, nên mọi SĐT đúng SRS đều bị chặn và mọi SĐT sai SRS (không bắt đầu bằng 0) lại lọt.
- BUG-04: `backend/server.js:119-125` destructure `role` từ `req.body` và ghép thẳng vào câu `UPDATE`, không hề kiểm quyền.
- BUG-05: `frontend-web/src/pages/Checkout.jsx:8` có `const { cart, cartTotal, clearCart } = useCart();` nhưng `handleCheckout` (dòng 40–66) **không bao giờ gọi `clearCart()`** — biến được import rồi bỏ quên.
- BUG-06: `backend/server.js` (`POST /api/apply-coupon`) tính `discount_amount = Math.floor(total_amount * (1 - coupon.discount_value))`. `discount_value` được seed là **10** (nghĩa là 10%), nên biểu thức thành `total * (1 - 10) = -9 * total`. Công thức đúng phải là `total * discount_value / 100`. Lỗi xuất hiện ở **cả hai** nhánh (có và không có `user_id`).
- BUG-07: hai tầng cùng lỗi — `Checkout.jsx:93-102` render tổng tiền bằng `<input type="number">` có `onChange` sửa `editableTotal`, và `handleCheckout` gửi chính giá trị đó; `server.js:297-307` nhận `total_amount` từ body rồi `INSERT` thẳng, **không hề đọc `items` để tính lại**. Sửa một tầng vẫn chưa đủ.
- BUG-08: `server.js` kiểm `if (total_amount > coupon.min_order_amount)` — dùng `>` nên loại trừ đúng điểm biên mà FR-09 C3 quy định là hợp lệ.
- BUG-09: cùng gốc với BUG-07 — `POST /api/checkout` **bỏ qua hoàn toàn mảng `items`**, không kiểm rỗng, nên một request với giỏ rỗng vẫn `INSERT` thành công.

- BUG-10 và BUG-13 chung một gốc: `backend/server.js:549-550` có nhánh `if (currentStatus === "canceled" && status === "delivered") isValidTransition = true;` — một ngoại lệ cài cắm có chủ đích, và `frontend-admin/src/App.jsx:862-869` render đúng cái nút để khai thác nó. Tách 2 bug vì một cái ở tầng API (dữ liệu bị hỏng dù không qua UI) còn một cái ở tầng UI (mời người dùng thực hiện thao tác sai).
- BUG-11: `backend/server.js:100-110` — middleware `authenticateToken` chỉ gọi `jwt.verify` rồi gán `req.user = user` và `next()`, **không hề đọc `user.role`**. Trong khi đó **toàn bộ 6 endpoint** `/api/admin/*` (`import-products`, `coupons` POST/DELETE, `users` GET/DELETE, `orders` GET, `orders/:id/status` PUT) chỉ dùng đúng middleware này. Frontend admin có kiểm `role !== "admin"` ở `App.jsx:65-68` nhưng đó chỉ là kiểm **phía client**, vô nghĩa trước một request gọi thẳng API.
- BUG-12: `frontend-admin/src/App.jsx:799-804` render cột Địa chỉ bằng `dangerouslySetInnerHTML={{ __html: o.shipping_address }}`, trong khi giá trị này do **người mua tự nhập** và không hề được escape ở bất kỳ tầng nào.

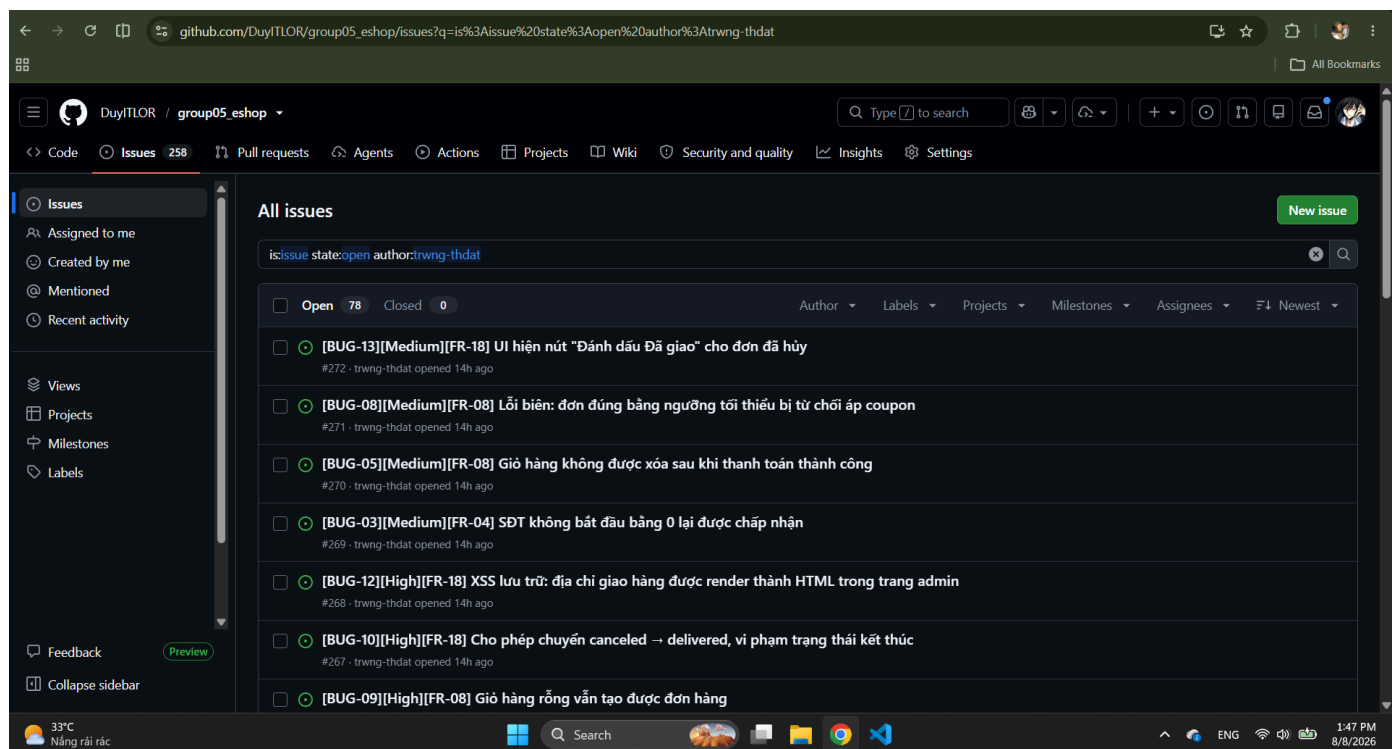
BUG-07 và BUG-09 chung một nguyên nhân gốc (`/api/checkout` tin tuyệt đối vào client, không tự tính lại từ `items`) nhưng được tách thành 2 bug vì biểu hiện, mức độ và cách kiểm khác nhau.

🔗 **Chuỗi khai thác nguy hiểm nhất** ghép từ 3 bug ở 2 feature: BUG-04 cho user tự nâng `role` thành `admin` qua PUT `/api/users/me`; nhưng thực ra **không cần** vì BUG-11 đã cho token user thường gọi thẳng mọi API admin; và BUG-12 cho phép chèn script qua địa chỉ giao hàng — script đó chạy **trong phiên của admin** khi admin mở tab Đơn hàng. Ba lỗi riêng lẻ, ghép lại thành đường chiếm quyền hoàn chỉnh.

Chi tiết đầy đủ: selenium/bug-snapshots/BUGS.md.

Bằng chứng đã tạo GitHub Issues

Cả **13 bug đều đã được báo cáo trên GitHub Issues** của repo SUT, mỗi issue kèm ảnh chụp — đáp ứng yêu cầu §6 (bug phải có mặt ở **cả** báo cáo Markdown **lẫn** GitHub Issues).



Ảnh lọc theo `is:issue state:open author:trwng-thdat` trên repo `DuyITLOR/group05_eshop` — thấy rõ thanh địa chỉ, tên tài khoản tác giả và quy ước tiêu đề `[BUG-xx][Mức độ][FR-xx]`.

Vùng hiển thị chỉ chứa 7 issue (#272 → #266) do giới hạn cuộn trang; đủ 13 issue **#260–#272** liệt kê kèm link ở [github_issues/README.md](https://github.com/DuyITLOR/group05_eshop/issues/README.md). Bộ đếm "Open 78" là tổng issue của tài khoản trên **toàn repo** (gồm cả bài tập khác), **không phải** số issue của HW04.

Chi tiết từng issue: [github_issues/](https://github.com/DuyITLOR/group05_eshop/issues) · nội dung gốc: `bug_report.md`.

TASK 2 — Demo video

Trọng số: **15/100**.

Hạng mục	Giá trị
Link YouTube (unlisted)	https://youtu.be/kbkZxUZHS_M
Thời lượng	05:50 (yêu cầu ≥ 5 phút)
Ngôn ngữ thuyết minh	Tiếng Việt (giọng thật của sinh viên)
Feature được demo	FR-04
Bằng chứng tác giả	Face-cam

TASK 3 — Agent Skill

Trọng số: **10/100**. Đề bài §7: khuyến khích xây Agent Skill đóng gói quy trình automation (data-driven, đa trình duyệt) để tái sử dụng cho các feature sau; nộp kèm video demo end-to-end.

Hạng mục	Giá trị
Tên skill	<code>selenium-automation</code>
Vị trí	<code>skills/selenium-automation/</code>
Video demo	https://youtu.be/1FvnyriJITQ
Feature dùng để demo	FR-08

Cấu trúc skill:

File	Vai trò
<code>SKILL.md</code>	Ràng buộc HW04, quy trình 9 bước, verification gate
<code>references/project-scaffold.md</code>	Code mẫu: config, driver factory, data loader, alert helper, report metadata, bug reporter
<code>references/review-checklist.md</code>	Checklist review thủ công output của AI (10 nhóm)
<code>references/eshop-notes.md</code>	Ghi chú selector/hành vi thật của EShop theo từng feature

Skill tự động hóa những gì:

Cơ chế	Ràng buộc HW04 được ép tự động
<code>dataLoader.loadCases()</code>	Ném lỗi ngay nếu file dữ liệu < 12 case hoặc có <code>tcId</code> trùng — không thể "quên" mốc ≥12 rồi phát hiện lúc nộp
<code>runMatrix.ts</code>	Tên file báo cáo suy ra từ browser đang chạy (<code>chrome.html/edge.html/firefox.html</code>), chặn lỗi kinh điển 3 lượt đề lên 1 file
<code>reportMetadata.injectMetadata()</code>	Chèn banner <code>Run by: + ISO timestamp</code> vào từng file HTML sau mỗi lượt, đáp ứng §11 chống gian lận
<code>verifyReports.ts</code>	Cổng kiểm cuối: đếm case, kiểm đủ 9 file HTML tồn tại đồng thời , và trích đúng thẻ banner rồi kiểm <code>Run by: / ISO / đúng tên browser</code>
<code>bugReporter.ts</code>	Tự chụp màn hình + ghi <code>BUGS.md</code> mỗi khi có test FAIL; xóa bằng chứng cũ theo từng feature để ảnh luôn khớp lần chạy hiện tại
<code>alerts.ts</code>	Bọc mọi thao tác sinh <code>alert()</code> — SUT này dùng alert làm kênh phản hồi chính, để rõ một alert là hỏng toàn bộ test phía sau
Quy trình trong <code>SKILL.md</code>	Bắt buộc đọc source thật trước khi viết selector , và phân loại FAIL thành lỗi script vs defect SUT thay vì nói assertion cho test xanh

Đã dùng lại được ở đâu: áp dụng cho **cả 3 feature** (FR-04 · FR-08 · FR-18). Phần khung dùng chung (`config`, `driver`, `dataLoader`, `alerts`, `reportMetadata`, `bugReporter`, `runMatrix`, `verifyReports`) viết **một lần** ở FR-04 rồi dùng lại nguyên vẹn cho FR-08 và FR-18 — mỗi feature sau chỉ cần thêm đúng 3 file: 1 data file, 1 spec, 1 page object.

Giá trị thực tế đo được qua 3 lần dùng — skill không chỉ tiết kiệm thời gian mà **chặn được lỗi thật**:

- **Ràng buộc ≥12 case** được kiểm ở tầng loader nên cả 3 feature đều đạt (15/16/16) mà không phải đếm tay.
- **Cổng kiểm bắt lỗi thật:** chính `verifyReports.ts` phát hiện 3 báo cáo FR-04 chưa được đóng dấu dù mocha báo chạy thành công (§1.6 dòng 5).

- **Điểm yếu cũng lộ ra khi tái sử dụng:** `resetBugLog()` đúng cho 1 feature nhưng xóa nhầm bằng chứng khi có 2 (§1.6 dòng 16), và mật khẩu admin sai trong `SKILL.md` lan sang tận FR-18 (§1.6 dòng 17). Cả hai đã được **sửa ngược lại vào skill**, không chỉ sửa ở nơi phát sinh lỗi — đây mới là điểm khiến skill dùng lại được lâu dài.

4. Tổng kết kiểm thử (Test Summary)

Số liệu này lặp lại trong `README.md` theo yêu cầu §14.

Chỉ số	Giá trị
Số feature tự động hóa	3 / 3 (FR-04 · FR-08 · FR-18)
Số test case đã thiết kế	47 (FR-04: 15 · FR-08: 16 · FR-18: 16)
Số test case tự động hóa	47 / 47 (≥36 theo yêu cầu)
Số test case đã thực thi	141 lượt (47 TC × 3 trình duyệt)
Số test case PASS	102 lượt (34 TC × 3)
Số test case FAIL	39 lượt (13 TC × 3) — đều là defect thật của SUT
Số lượt chạy trình duyệt	9 / ≥9
Số báo cáo HTML	9 / 9 (tồn tại đồng thời, đã qua cổng kiểm)
Số bug phát hiện	13 (3 Critical · 5 High · 5 Medium)
Số GitHub Issue đã tạo	13 / 13 — #260 — #272
Số TC không tự động hóa được	0 / 47
Link video demo	https://youtu.be/kbkZxUZHS_M

Đã đạt toàn bộ mốc định lượng của đề bài: 3 feature Pool A/B/C, ≥12 TC mỗi feature, ≥3 assertion pattern mỗi feature, 9 báo cáo HTML có `Run by`: + ISO timestamp. Còn thiếu: GitHub Issues, video demo, `AI_Critique.md`.

5. Git commit log

Yêu cầu §12: repo public, ≥ **8 commit trong ≥ 4 ngày khác nhau**. Chỉ commit có thay đổi file test script (`.spec.ts` / `.spec.js` hoặc tương đương) mới được tính; commit chỉ sửa README/PDF/tài liệu **không tính**.

Chỉ số	Giá trị
Repo public (chứa scripts)	https://github.com/trwng-thdat/software-testing
Tổng số commit liên quan HW04	27 (thư mục <code>hw4/</code>)
Số commit có dụng file test	8 (yêu cầu ≥ 8)
Số ngày khác nhau có commit HW04	5 (yêu cầu ≥ 4)
Khoảng thời gian	25/07/2026 – 08/08/2026
File log	<code>git_commit_log.txt</code>

Cách đếm — bám đúng câu chữ §12:

"at least 8 commits over at least 4 days. Only commits that change **test-script files** (`.spec.js`, `.spec.ts`, or equivalent) count toward the **8-commit minimum**."

Ràng buộc "chỉ tính file test" gắn với **mốc 8 commit**, còn mốc **4 ngày** áp cho lịch sử repo nói chung. Vì vậy `git_commit_log.txt` xuất **hai phần**: [A] commit dụng file test, [B] toàn bộ commit HW04.

Nhóm	Phạm vi file	Commit	Ngày
[A] File test script	<code>*.spec.ts</code> + <code>data/*.data.json</code> + <code>utils/*.ts</code>	8	29/07 · 07/08
[B] Toàn bộ HW04	<code>hw4/**</code>	27	25/07 · 26/07 · 29/07 · 07/08 · 08/08 → 5 ngày

Lệnh sinh log:


```
# [A] commit dựn file test script (mốc >= 8 commit)
git log --pretty=format:"%h | %ad | %an | %s" --date=iso -- "*.spec.ts" "hw4/selenium/data/*"
"hw4/selenium/utls/*"

# [B] toàn bộ commit HW04 (mốc >= 4 ngày)
git log --pretty=format:"%h | %ad | %an | %s" --date=iso -- hw4/
```

6. Tự đánh giá (Self-Assessment)

No.	Tiêu chí	Điểm tối đa	Tự chấm	Căn cứ
1	Task 1 — Feature A (FR-04)	25	25	15 TC · 3 báo cáo HTML · 11 PASS/4 FAIL · 4 bug (#260, #263, #264, #269) · §1.3.1–1.8
2	Task 1 — Feature B (FR-08)	25	25	16 TC · 3 báo cáo HTML · 11 PASS/5 FAIL · 5 bug (#261, #265, #266, #270, #271) · §1.3.2
3	Task 1 — Feature C (FR-18)	25	25	16 TC · 3 báo cáo HTML · 12 PASS/4 FAIL · 4 bug (#262, #267, #268, #272) · §1.3.3
4	Task 2 — Demo video	15	15	https://youtu.be/kbkZxUZHS_M — tự kiểm thời lượng ≥5 phút
5	Agent Skill	10	10	selenium-automation , tái sử dụng cho cả 3 feature · https://youtu.be/1FvnyriJITQ
Tổng		100	100	Đạt đủ mốc §12: 8 commit file test · 5 ngày (chi tiết §5)

Căn cứ chấm tối đa — đối chiếu từng ràng buộc bắt buộc của đề bài:

Ràng buộc	Yêu cầu	Thực tế	Đạt
Số feature Pool A/B/C	3	3	✓
Test case tự động hóa	≥ 36	47	✓
Test case mỗi feature	≥ 12	15 · 16 · 16	✓
Dữ liệu tách file <code>.json/.csv</code>	bắt buộc	3 file, spec duyệt mảng	✓
Assertion pattern mỗi feature	≥ 3	4 · 5 · 5	✓
Lượt chạy trình duyệt	≥ 9	9	✓
Báo cáo HTML tồn tại đồng thời	9	9	✓
Run by: {MSSV} + ISO timestamp hiển thị	bắt buộc	Đã xác minh render thật + ảnh chụp	✓
Bug ở Markdown và GitHub Issues	bắt buộc	13 bug · 13 issue #260–#272	✓
Commit dựn file test	≥ 8	8	✓
Số ngày có commit	≥ 4	5	✓
AI Audit Report	bắt buộc	5 artifact	✓
AI Critique 200–300 từ	bắt buộc	273 từ	✓
Video Task 2 + video Agent Skill	bắt buộc	2 video	✓

Toàn bộ mốc định lượng đều **đạt hoặc vượt**. Điểm cộng thêm nằm ở chiều sâu: phát hiện **13 defect thật** (3 Critical) trong đó có chuỗi khai thác ghép BUG-04 → BUG-11 → BUG-12; giữ nguyên **39 lượt test FAIL** làm bằng chứng thay vì nới assertion; và bảng §1.6 ghi **19 lỗi AI** đã sửa kèm nguyên nhân gốc, gồm cả những lỗi mà chính bộ kiểm chứng tự động **không** bắt được.

7. Phụ lục

Tài liệu	Nội dung
[AI-02] - AI Audit Report	Phụ lục bắt buộc — log toàn bộ tương tác AI

Tài liệu	Nội dung
AI_Critique.md	Bắt buộc — 200–300 từ phê bình AI
README.md	Bảng tự đánh giá + test summary
git_commit_log.txt	Log commit
bug_report.md	13 issue soạn sẵn — title, description, ảnh cần chèn
selenium/bug-snapshots/BUGS.md	Bug report chi tiết sinh tự động khi chạy test
skills/selenium-automation/	Agent Skill

7.1 Checklist trước khi nộp

- ☐ 3 feature đúng Pool A / B / C, khớp HW02 (hoặc đã giải trình)
- ☐ ≥ 12 TC tự động hóa **mỗi** feature (≥ 36 tổng)
- ☐ Dữ liệu test nằm ở file `.json/.csv` riêng — không hardcode trong spec
- ☐ ≥ 3 assertion pattern khác biệt mỗi feature
- ☐ 9 file báo cáo HTML tồn tại **đồng thời**, không đè lên nhau
- ☐ Mọi báo cáo hiển thị `Run by: [MSSV]` + ISO timestamp khi mở bằng trình duyệt
- ☐ Bảng phân tích AI sai/thiếu (§1.6) đã điền, có nguyên nhân gốc
- ☐ Danh sách TC không tự động hóa được (§1.7) đã điền
- ☒ Bug đã log **cả** trong Markdown **và** GitHub Issues, mỗi issue có ảnh — 13 issue #260–#272, ảnh chụp ở `github_issues/`
- ☐ Video ≥ 5 phút, tiếng Việt, có `whoami/hostname` hoặc face-cam, có giải thích 1 lỗi đã sửa
- ☐ Agent Skill + video demo skill
- ☐ AI Audit Report + AI Critique (200–300 từ), cả `.md` và `.pdf`
- ☐ ≥ 8 commit đùng file test, trải ≥ 4 ngày
- ☐ `README.md` có bảng tự đánh giá + test summary
- ☐ Tên file zip: `23127344_HW04_AI_Automation_100.zip`

⚠ §17: nộp trễ không được chấp nhận; **thiếu bất kỳ tài liệu bắt buộc nào** → **0 điểm**; sao chép giữa sinh viên (kể cả prompt) → 0 điểm cho cả hai bên.